Lab A/B: Aufbau eines Labs zum Thema E-Pass Authentifizierung



Inhaltsverzeichnis

AUFGABENBESCHREIBUNG 3

ERKLÄRUNG DES E-PASS STANDARDS 3

SIMULATION DER AUTHENTIFIZIERUNGSSCHRITTE 4

ANALYSE VON SCHWACHSTELLEN 4

SICHERHEITSMASSNAHMEN 7

FAZIT 7

QUELLEN 8

Aufgabenbeschreibung

Ziel dieses Labs ist der Aufbau und die Analyse eines Systems zur Authentifizierung von elektronischen Pässen (E-Pass).

Fallbeispiel:
Ein Grenzposten möchte ein System zur Authentifizierung von elektronischen Pässen testen.

Erklärung des E-Pass Standards

Der ePass ist ein elektronischer, maschinenlesbarer Reisepass. Technisch basiert er auf dem internationalen Standard Doc 9303 der International Civil Aviation Organization (ICAO). Ziel dieses Standards ist es, dass Reisepässe weltweit einheitlich ausgelesen und geprüft werden können und dass die im Pass gespeicherten Daten kryptografisch auf Echtheit und Unverändertheit überprüfbar sind.

Ein ePass enthält zusätzlich zur gedruckten Datenseite einen kontaktlosen Chip. Das bekannte „ChipInside“-Symbol weist auf diese Funktion hin und darf nur verwendet werden, wenn der Pass die Mindestanforderungen des Standards erfüllt (z. B. korrekte Datenstruktur und Absicherung durch digitale Signaturen). Der Chip kann mit geeigneten Lesegeräten aus kurzer Distanz ausgelesen werden.

Die Daten im Chip sind in der sogenannten „Logical Data Structure“ (LDS) organisiert und in Datenbereiche („Data Groups“ oder DG) unterteilt. Die Mindestbestandteile eines konformen ePasses sind:

- **DG1**: elektronische Kopie der maschinenlesbaren Zone (MRZ)
- **DG2**: Gesichtsbild als biometrisches Merkmal
- **EF.SOD**: signiertes Sicherheitsobjekt mit Hashwerten zur Integritätsprüfung

Für zusätzliche biometrische Daten existieren optionale Bereiche wie **DG3** (Fingerabdrücke) und **DG4** (Irisdaten), deren Nutzung vom jeweiligen Staat abhängt. Die Trennung in Datenbereiche ermöglicht klar definierte Prüfverfahren, etwa Integritätsprüfungen anhand von Hashwerten.

Sicherheitsseitig gibt es mehrere Schichten. Die wichtigste Grundprüfung ist die **Passive Authentication**, bei der die Signatur des EF.SOD geprüft und Hashwerte verglichen werden, um die Echtheit und Unverändertheit der Daten sicherzustellen. Diese Prüfung verhindert jedoch nicht das vollständige Kopieren eines Chips (Klonen), weshalb zusätzliche Massnahmen erforderlich sind.

Zum Schutz vor unbefugtem Auslesen nutzt der Standard-Zugriffskontrollen wie **Basic Access Control (BAC)** und modernere Verfahren wie **PACE**. Beide bauen nach erfolgreicher Authentisierung einen geschützten Kommunikationskanal („Secure Messaging“) auf. Bei BAC werden Schlüssel aus MRZ-Daten abgeleitet, während PACE zusätzlich eine Card Access Number (CAN) unterstützt und robustere Sitzungsschlüssel erzeugt.

Optional existieren Mechanismen wie **Active Authentication** und **Chip Authentication**, die sicherstellen, dass es sich um den echten Chip handelt. Für besonders schützenswerte Daten wird teilweise **Extended Access Control (EAC)**

eingesetzt, das zusätzliche Zugriffsbeschränkungen (z. B. Terminalberechtigungen) berücksichtigt.

Insgesamt kombiniert der ePass-Standard einheitliche Datenformate (LDS), kryptografische Integritäts- und Echtheitsprüfungen (EF.SOD/PKI) sowie Zugriffsschutz auf die Funkkommunikation (BAC/PACE und ggf. EAC). Dadurch kann der Reisepass im internationalen Grenzverkehr schneller maschinell geprüft und besser gegen Manipulation abgesichert werden als rein gedruckte Dokumente.

Simulation der Authentifizierungsschritte

In diesem Lab wurde die Authentifizierung eines elektronischen Reisepasses nicht nur theoretisch betrachtet, sondern praktisch simuliert. Ziel war es, die einzelnen Sicherheitsmechanismen realitätsnah nachzustellen und deren Ablauf besser zu verstehen.

Zuerst wurden die Daten aus der sogenannten Machine Readable Zone (MRZ) verwendet. Diese befinden sich auf der Datenseite des Passes und enthalten unter anderem die Passnummer und das Geburtsdatum. Auf Basis dieser Informationen wurde ein Schlüssel berechnet, der für die Basic Access Control (BAC) benötigt wird. Mit diesem Schlüssel konnte eine verschlüsselte Verbindung zwischen dem Lesegerät und dem Chip aufgebaut werden. Dadurch wurde sichergestellt, dass nur autorisierte Geräte Zugriff auf die Daten erhalten.

Anschliessend wurde die Passive Authentication (PA) durchgeführt. Dabei wurde überprüft, ob die im Chip gespeicherten Daten unverändert und echt sind. Dies geschieht mithilfe von digitalen Signaturen. In der Simulation wurde dieser Prozess vereinfacht dargestellt, indem Hashwerte verglichen und Zertifikate geprüft wurden. (3)

Daraufhin wurde zusätzlich die Chip Authentication (CA) durchgeführt. Diese ist ein moderner Sicherheitsmechanismus im Rahmen der Extended Access Control. Dabei wird zwischen dem Lesegerät und dem Chip ein kryptographischer Schlüsselaustausch durchgeführt, wodurch eine neue, besonders sichere Sitzung aufgebaut wird. Dies stellt sicher, dass der Chip authentisch ist und schützt gleichzeitig die Kommunikation vor Abhören und Manipulation.

Im nächsten Schritt folgte die Active Authentication (AA). Hierbei wurde getestet, ob der Chip tatsächlich original ist und nicht kopiert wurde. Dazu wurde ein Challenge-Response-Verfahren simuliert: Das System sendete eine zufällige Anfrage an den Chip, welcher diese mit einem geheimen Schlüssel beantwortete. Die Antwort wurde anschliessend überprüft.

Die Simulation hat gezeigt, wie mehrere Sicherheitsmechanismen zusammenarbeiten, um sowohl den Zugriff zu kontrollieren als auch die Echtheit der Daten und des Chips sicherzustellen. Dadurch konnte ein tieferes Verständnis für die komplexen Abläufe der E-Pass Authentifizierung gewonnen werden.

Analyse von Schwachstellen

Der E-Pass gilt als sicherer als sein Vorgänger und ist es in vielen Bereichen auch. Trotzdem gibt es Angriffsflächen, die in der Praxis relevant bleiben. Die folgenden vier Schwachstellen betreffen aktuelle Systeme und sind nicht rein theoretisch.

Kryptografische Schwachstelle (Passive Authentication)

Betroffene Systeme	Alle ICAO-konformen E-Pässe, die keine Chip Authentication (CA) erzwingen
Technischer Kern	Passive Authentication (PA) verifiziert die digitale Signatur der gespeicherten Chip-Daten nicht die Identität des Chips selbst. Da alle Daten inklusive Signatur öffentlich lesbar sind, können sie vollständig auf einen beschreibbaren RFID-Rohling kopiert werden. Der Klon besteht die PA-Prüfung, weil die originale Länder-Signatur mitkopiert wird.
Angriffsvektor	Angreifer liest Chip mit NFC-Lesegerät aus, kopiert alle Datengruppen (SOD, DG1, DG2 etc.) auf Rohling geklonter Pass passiert Grenzkontrolle

RFID / NFC (Skimming)

Betroffene Systeme	Ältere Pässe mit Basic Access Control (BAC), noch viele im Umlauf (Gültigkeitsdauer 10 Jahre)
Technischer Kern	BAC leitet den Sitzungsschlüssel aus der MRZ ab. Da Geburtsdatum, Ablaufdatum und Passnummer Muster aufweisen, ist der Schlüsselraum kleiner als theoretisch möglich. Ohne RF-Abschirmung kann ein verstecktes Lesegerät aus wenigen Zentimetern Distanz eine NFC-Verbindung aufbauen und Daten auslesen.
Angriffsvektor	Angreifer mit verstecktem Lesegerät nähert sich Opfer in der Öffentlichkeit (Zug, Warteschlange). MRZ-Daten und Gesichtsbild werden still ausgelesen ohne jede Interaktion.

RFID / NFC (Relay-Angriff)

Betroffene Systeme	Alle NFC-basierten Pässe, unabhängig von PACE oder CA
Technischer Kern	Beim Relay-Angriff wird die NFC-Kommunikation in Echtzeit über eine grössere Distanz weitergeleitet. Angreifer A steht neben dem Opfer und kommuniziert mit dessen Pass, Angreifer B steht am Grenzlesegerät und emuliert den Pass. Da kein Protokoll die physische Distanz misst, sieht die Kommunikation aus wie ein normaler Kontakt.

Angriffsvektor	Koordiniertes Vorgehen zweier Angreifer: Einer neben dem Opfer, einer am Kontrollpunkt. Die Challenge-Response-Kommunikation wird ohne Verzögerung weitergeleitet. Auch PACE und CA bieten keinen Schutz

Biometrische Schwachstellen

Gesichts- und Fingerabdruck-Spoofing

Betroffene Systeme	Automatisierte Grenzkontrollsysteme (ABC-Gates) ohne Liveness Detection
Technischer Kern	Gesichtserkennung ohne Liveness Detection prüft nur den visuellen Abgleich ein hochauflösendes Foto oder eine 3D-Maske kann genügen. Fingerabdruckscanner ohne kapazitive Lebenderkennung akzeptieren Silikonrepliken, die aus latenten Abdrücken hergestellt werden (handelsübliche Materialien, kein Spezialwissen nötig).
Angriffsvektor	Gesicht: Foto des Opfers beschaffen, ausdrucken oder 3D-Maske erstellen, vor Kamera halten. Fingerabdruck: Latenten Abdruck sichern (z.B. von Glasoberfläche), Negativform giessen, Silikonabdruck anfertigen.

Datenschutzrisiko durch zentrale Speicherung

Betroffene Systeme	Nationale Grenzdatenbanken, die biometrischen Merkmale bei Übertritten speichern
Technischer Kern	Biometrische Merkmale sind unveränderlich, ein kompromittiertes Kennwort kann geändert werden, ein Fingerabdruck nicht. Zentrales Logging erzeugt einen Datensatz, der bei einem Leak dauerhaft gefährdet bleibt. Zusätzlich besteht das Risiko der Zweckentfremdung: Daten, die für Grenzkontrolle erhoben wurden, können für Überwachung oder Profiling genutzt werden.
Angriffsvektor	Kompromittierung einer zentralen Datenbank gibt biometrische Merkmale von Millionen Personen dauerhaft preis.

Kein einzelner Mechanismus deckt alle Schwachstellen ab. PA allein reicht nicht aus, solange CA nicht erzwungen wird. PACE löst das Skimming-Problem, nicht aber Relay-Angriffe. Liveness Detection ist bei biometrischen Systemen essenziell, ohne sie ist Spoofing trivial. Das eigentliche Risiko beim Datenschutz liegt nicht im Angriff auf den Pass selbst, sondern in der Infrastruktur drumherum.

Sicherheitsmassnahmen

Auf Basis der analysierten Schwachstellen lassen sich verschiedene Sicherheitsmassnahmen ableiten, die dazu beitragen, die Authentifizierung von elektronischen Pässen robuster und sicherer zu gestalten.

Zum Schutz vor dem Klonen eines Chips ist der Einsatz von Chip Authentication (CA) entscheidend. Während die Passive Authentication lediglich die Echtheit der Daten prüft, stellt die Chip Authentication sicher, dass tatsächlich der originale Chip antwortet. Dadurch wird verhindert, dass kopierte Daten erfolgreich verwendet werden können.

Gegen das unbefugte Auslesen von Daten (Skimming) bieten modernere Verfahren wie PACE (Password Authenticated Connection Establishment) einen verbesserten Schutz im Vergleich zu BAC. Zusätzlich können physische Schutzmassnahmen wie RFID-abschirmende Passhüllen eingesetzt werden, um ein unbemerktes Auslesen in der Öffentlichkeit zu verhindern.

Relay-Angriffe stellen weiterhin eine Herausforderung dar, da sie auch bei modernen Verfahren möglich sind. Eine mögliche Gegenmassnahme ist der Einsatz von Distanzmessungen (Distance Bounding), bei denen die Laufzeit der Kommunikation überprüft wird, um ungewöhnlich grosse Entfernungen zu erkennen. Solche Verfahren befinden sich jedoch teilweise noch in der Weiterentwicklung.

Im Bereich der biometrischen Systeme ist der Einsatz von Liveness Detection besonders wichtig. Dabei wird geprüft, ob es sich um eine lebende Person handelt, beispielsweise durch Bewegungen oder Tiefeninformationen. Dadurch können Angriffe mit Fotos, Masken oder künstlichen Fingerabdrücken deutlich erschwert werden.

Auch aus Datenschutzsicht sind zusätzliche Massnahmen erforderlich. Dazu gehören insbesondere die Minimierung der gespeicherten Daten, eine dezentrale Speicherung sensibler Informationen sowie strenge Zugriffskontrollen. Da biometrische Daten nicht verändert werden können, ist ihr Schutz besonders kritisch.

Insgesamt zeigt sich, dass ein wirksamer Schutz nur durch die Kombination mehrerer technischer und organisatorischer Massnahmen erreicht werden kann. Einzelne Mechanismen sind nicht ausreichend, um alle Angriffsvektoren abzudecken.

Fazit

Der elektronische Reisepass stellt eine deutlich sicherere Weiterentwicklung gegenüber herkömmlichen Dokumenten dar, da er kryptografische Verfahren und biometrische Merkmale kombiniert. Die Analyse hat jedoch gezeigt, dass trotz moderner Sicherheitsmechanismen weiterhin relevante Schwachstellen bestehen, insbesondere bei Relay-Angriffen und biometrischen Systemen. Einzelne Schutzmechanismen reichen nicht aus, um alle Angriffsvektoren vollständig abzudecken. Entscheidend ist daher der kombinierte Einsatz mehrerer technischer und organisatorischer Massnahmen. Insgesamt hängt die tatsächliche Sicherheit nicht nur vom E-Pass selbst, sondern auch stark von der umgebenden Infrastruktur und deren Umsetzung ab.

Quellen

Erklärung des E-Pass Standards:

https://www.icao.int/icao-pkd/epassport-basics
https://www.icao.int/sites/default/files/publications/DocSeries/9303_p9_cons_en.pdf
https://www.icao.int/sites/default/files/TRIP/Publications/Doc-9303-7th-Part11.pdf
https://www.icao.int/sites/default/files/publications/DocSeries/9303_p10_cons_en.pdf

Simulation der Authentifizierungsschritte

https://www.icao.int/icao-pkd/epassport-basics
https://www.icao.int/sites/default/files/publications/DocSeries/9303_p9_cons_en.pdf
https://www.icao.int/sites/default/files/TRIP/Publications/Doc-9303-7th-Part11.pdf
https://www.icao.int/sites/default/files/publications/DocSeries/9303_p10_cons_en.pdf

Analyse von Schwachstellen

https://www.icao.int/publications/doc-series/doc-9303
https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/TechGuidelines/TR03110/BSI_TR-03110_Part-1_V2-2.pdf?__blob=publicationFile&v=1
https://eprint.iacr.org/2005/095.pdf
https://www.bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr03110/tr-03110.html
https://www.rfidblog.org.uk/hancke-rfidrelay.pdf
https://eprint.iacr.org/2005/052
https://grundrechte.ch/2013/Impact_of_Artificial_Gummy_Fingers_on_Fingerprint_Systems.pdf
https://www.iso.org/standard/53227.html
https://gdpr-info.eu/
https://www.enisa.europa.eu/topics/digital-identity-and-data-protection

Sicherheitsmassnahmen
https://www.icao.int/publications/doc-series/doc-9303
https://www.signicat.com/blog/overview-security-mechanisms-in-epassports
https://www.sciencedirect.com/science/article/pii/S1874548214000614
https://www.signicat.com/blog/privacy-related-security-mechanisms-for-epassports
https://en.wikipedia.org/wiki/Biometric_passport